Audit de sécurité - Plateforme Code un max

Analyser une campagne de phising ciblée contre Code un max

1. Préparation d'un fichier courriel suspect

```
(
echo "Objet : URGENT - Mise à jour requise de votre accès formateur Code un
max"
echo "De : support@code-un-max-fr.verif-compte.net"
echo "Bonjour Brandon,"
echo "Suite à une maintenance de sécurité sur notre plateforme de cours,
vous devez impérativement valider votre session administrateur sous 24h via
le portail dédié :"
echo "https://code-un-max-fr.verif-compte.net/connexion"
echo "Cordialement, l'équipe support technique."
) > courriel-suspect.txt
```

1.1 Copier le fichier dans le conteneur attaquant

```
docker cp courriel-suspect.txt attaquant:/tmp/courriel-suspect.txt
```

2. Identifier les marqueurs de spear phishing

- **Prénom de la cible** : S'adresse directement à la personne concernée par son véritable prénom ce qui permet de briser la méfiance à l'égard du destinataire.
- **Contexte professionnel ("Formateur Code un max", "session administrateur")** : L'attaquant connaît exactement le poste de la victime et la plateforme qu'elle utilise, ce qui donne une légitimité.
- **Pression physchologique basée sur l'urgence ("URGENT", "sous 24h")** : La phychologie basée sur l'urgence pousse la victime à agir dans la précipitation, ce qui réduit la capacité de la victime à réfléchir sérieusement.

3. Extraire et classer les URL du message

3.1 Création d'un fichier contenant plusieurs variantes d'URL

```
(
echo https://code-un-max.fr/connexion
echo https://code-un-max-fr.verif-compte.net/connexion
echo https://code-un-max.fr.session-login.ru/
echo https://xn--code-un-mx-8bb.fr/connexion
```

```
  echo https://code-un-max.fr@phishing-serveur.net/connexion
  ) > urls-suspectes.txt
```

3.2 Copier le fichier dans le conteneur attaquant

```
docker cp urls-suspectes.txt attaquant:/tmp/urls-suspectes.txt
```

3.3 Filtrer et isoler les URL qui finissent pas par le vrai domaine

```
docker exec attaquant grep -E "(verif-compte|session-login|phishing-
serveur|xn--)" /tmp/urls-suspectes.txt
```

URL suspecte	Technique de leurre	Domaine réellement contacté
`https://code-un-max.fr`	**Domaine légitime (Référence)**	code-un-max.fr
`https://verif-compte.net`	**Sous-domaine trompeur** (le nom légitime est placé en sous-domaine pour abuser de la confiance)	verif-compte.net
`https://session-login.ru`	**Fausse extension / Domaine tiers**	session-login.ru
`https://xn--code-un-mx-8bb.fr`	**Attaque par homographie (Punycode)** (utilisation de caractères Unicode ressemblants)	xn--code-un-mx-8bb.fr (qui simule code-un-max.fr)
`https://code-un-max.fr@phishing-serveur.net/connexion`	**Leurre par arobase (@)** (le navigateur ignore tout ce qui précède l'arobase dans l'authentification/URL)	phishing-serveur.net

4. Décoder un domaine Punycode trompeur

4.1 installer l'outil `idn`

```
docker exec attaquant bash -c "apt-get update && apt-get install -y idn"
```

4.2 Révéler la forme lisible du domaine Punycode

```
python3 -c "print('xn--code-un-mx-8bb.fr'.encode('utf-8').decode('idna'))"
```

Résultat obtenu : `code-unõ-mx.fr`

5. Évaluation du risque de menace intérieur

5.1 Insider accidentel (négligence ou erreur humaine)

- **Scénario** : Un formateur ou un employé de Code un max, fatigué ou pressé, reçoit le courriel simulant une mise à jour de sécurité urgente. Ne voyant pas le piège du domaine en Punycode ou du sous-domaine trompeur, il clique sur le lien, saisit ses identifiants et compromet son compte sans aucune intention de nuire.
- Signaux faibles de détection :
  - Connexion au compte depuis une adresse IP géographiquement incohérente ou un appareil inconnu.
  - Multiples tentatives de connexion infructueuses suivies d'une connexion réussie juste arès la réception d'une campagne de phishing

5.2 L'insider malveillant (Complicité ou compromission volontaire)

- **Scénario** : Un utilisateur interne mécontent ou corrompu utilise sa position pour fournir des informations ciblées sur l'organisation (organigramme, rôles précis des formateurs) afin de peaufiner le spear phishing, ou facilite l'accès direct aux infrastructures de la plateforme.
- **Signaux faibles de détection** :
  - Consultation ou extraction massive de données sensibles (listes de comptes, bases de données) en dehors des horaires de travail habituels.
  - Utilisation d'outils non autorisés ou tentatives de contournement des contrôles de sécurité internes (bypass des journaux de logs, utilisation de canaux de communication alternatifs).

6. Rédaction de recommandations de sensibilisation

6.1 Mesures Techniques

- **Techniques** : Filtrage de messagerie (SPF/DKIM/DMARC), réécriture des URL, MFA résistant au phishing.

- **Humaines** : Réflexe du survol des liens, double validation (out-of-band), simulations régulières. Création de fixe réflexes.

6.2 Procédure de signalement d'un courriel suspect

- **Étape 1 (Employé)** : Dès qu'un courriel présente un doute, l'employé utilise le bouton de signalement intégré dans sa messagerie ou transfère le message brut à l'adresse dédiée sans cliquer sur les liens.
- **Étape 2 (Analyse par des outils)** : Analyser le courriel par un outil qui automatise et extrait les indicateurs de compromission, hachages de pièces jointes et domaines malveillants pour évaluer la menace.
- **Étape 3 (Intervention de l'analyste)** : Le SOC confirme la dangerosité et révoque immédiatement les sessions potentiellement compromises et lance un blocage vers le domaine malveillant identifié.